

1. Análisis y planificación del pentest

Objetivo del pentest
1. Identificar puertos abiertos haciendo un escaneo, buscando detectar posibles puertas de entrada.
2. Verificar la disponibilidad, confiabilidad e integridad de la información almacenada.
3. Determinar el impacto real de las vulnerabilidades mediante explotación.

2. Alcance

Sí se evaluará
1. Escaneo de red autorizada
2. Mapeo de puertos abiertos buscando identificar puertas de acceso que representan un peligro potencial.
3. Explotación de vulnerabilidades para determinar el alcance que puede tener la información encontrada.

Fuera del alcance
1.No se atacaran redes sociales de la empresa
2.No atacar cuentas de correo electrónico
3.No comprometer equipos personales de los empleados.
4. No proveedores externos ni sistemas que no formen parte del alcance acordado
5. Ataques de denegación de servicio ya que el cliente solicita hacer la prueba en horario de menor actividad tratando de evitar totalmente esta acción.

3. Autorización y condiciones

Permisos requeridos
1. Autorización de análisis y escaneo.
2. Uso exclusivo de herramientas previamente pactadas y aprobadas por la empresa para el análisis.
3. Explotación de vulnerabilidades para determinar alcance y sugerir soluciones.
4. Permiso de uso de herramientas en entorno controlado (sistema operativo autorizado para realizar las pruebas).

Condiciones acordadas

1. No está permitida la corrupción de datos al hacer el análisis
2. No está permitido rebasar el alcance autorizado por el cliente, la prueba incluye únicamente la plataforma web.
3. Confidencialidad de todos los datos y vulnerabilidades encontradas mediante contrato.
4. Entrega de informe con estrategias para reducir o eliminar la probabilidad y en caso de encontrar un ataque detallar que fue lo que ocurrió.

4. Tipo de pentest

Tipo de pentest elegido: Gray-Box



Justificación

Se cuenta con información parcial que permite realizar el análisis, por solicitud del cliente no se brindan detalles internos.

5. Planificación

OBJETIVOS: Analisis de ip autorizada para obtener analisis de seguridad e identificar amenazas de seguridad.

ALCANCE: IP autorizada para análisis, puertos y servicios asociados al host.

PERMISOS Y CONDICIONES: herramientas de escaneo y auditoria (wireshark, searchsploit)

METODOLOGÍA A UTILIZAR: Prueba de penetración de caja gris sobre infraestructura y servicios de red.

RECOPIACIÓN DE INFORMACIÓN PREVIA: IP, tipo de entorno a utilizar, herramientas de análisis.

RECURSOS NECESARIOS:Virtual box, kali linux, Nmap, SeachSploit, Wireshark).

PROGRAMACIÓN DEL PENTEST: Hora cpon baja demanda en servicio, hora sugerida 2-4 am

6. Fases del pentest

1.RECONOCIMIENTO: Recopilar la mayor cantidad de información sobre la IP proporcionada, sin alterar datos ni funcionamiento.

2. ANÁLISIS DE VULNERABILIDADES: Analizar la información obtenida en la fase previa para identificar fallas de seguridad, malas configuraciones, servicios no parcheados o puertos expuestos de forma insegura.

3.EXPLOTAÇÃO: Realizar de manera controlada la explotación de las vulnerabilidades encontradas.

4. POST-EXPLOTACIÓN: Hacer análisis de acceso obtenido, identificar el alcance y si es posible acceder a otros segmentos de red por el host comprometido.

5. INFORME: Sintetizar el análisis técnico realizado, documentar la evidencia fotográfica y proponer medidas correctivas para neutralizar las vulnerabilidades encontradas.

7. Investigación

METODOLOGÍA ELEGIDA:

Para el desarrollo de esta actividad se ha seleccionado la metodología de Pruebas de Penetración de Caja Gris (Gray Box Pentesting) estructurada en un ciclo operativo de 5 fases (Reconocimiento, Análisis de Vulnerabilidades, Explotación, Post-explotación e Informe).

¿PORQUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

El tiempo y esfuerzo de la prueba se concentra en el análisis de puertos, por la información que proporciona el cliente, se descarta un ataque Black Box, debido a que se conocen datos del dominio. Representa de manera fiel la perspectiva de un atacante con información privilegiada (un empleado descontento, un socio comercial o un cibercriminal que obtuvo credenciales expuestas en fuentes abiertas OSINT), permitiendo medir el impacto real si un vector de entrada básico es comprometido.

La explotación se realiza de manera ética y no invasiva, se toman evidencias fotograficas en cada etapa y se entrega un informe completo y detallado de los hallazgos.